

ScamGuard — End-to-End Audit Report

Generated: 2026-08-12 14:56 IST · Repo: github.com/OCTOBER-sk/ScamGaurd · BYOK
scam-risk checker (OLX & Quikr) + Message & Payment Check

1 · System Overview

Chrome MV3 extension, vanilla ES modules, zero runtime dependencies. Heuristics run instantly (sub-1s, no network); an optional BYOK LLM call fuses with heuristics into a scored verdict. A second independent surface — Message & Payment Check — pattern-matches UPI/QR payment traps offline and always shows the core fact even with zero network.

Layer	Modules	Role
Extraction	content/extractor.js	Scrapes OLX/Quikr listing pages, confidence-graded
Heuristics	src/heuristics/*	Instant 0-100 pre-score (7 signals, deterministic)
Payment check	src/payment-check/*	6 scam patterns, offline, permissive matching
LLM layer	src/llm/providers/* (10)	Provider adapters, tolerant parse, schema validate, vision
Scoring	src/scoring/fuse.js	0.45/0.55 fusion, verdict bands, escalation floor
Storage	src/storage/*	Settings/history/session (chrome.storage.local only)
Orchestration	src/background/service-worker.js	Message router, persist-before-fetch, \$6 error matrix
UI	popup.* / options.*	Verdict seal, 8 states, message-check view, settings

2 · Automated Verification (fresh runs)

Test suite: node:test + jsdom — **254 / 254 pass**, 0 fail, 0 skip. Covers: extractor fixtures, heuristics weights, payment-check patterns, all 10 provider adapters with mocked fetch (500 retry / 429 no-retry / timeout / malformed-JSON repair / model-gone / no-vision / notAListing), fusion math & band boundaries, escalation override, storage round-trips & eviction, SW persist-before-fetch order, 8 popup states incl. stale-state-bleed guard, \$2.10 no-seal rule & coreFact-on-LLM-failure, options page outcomes.

Lint (i18n boundary guard): ok — 36 files scanned, no hardcoded string-literal concatenation in .textContent/.innerText outside src/strings/.

Manifest audit: MV3 · name ScamGuard · content_scripts matches exactly */**/*.olx.in/item/* and */**/*.quikr.com/* · permissions [storage, activeTab] · all provider hosts declared, NO <all_urls> · icons 16/32/48/128 present.

3 · Backend End-to-End Audit (real execution)

Real pipeline run on this VPS: real fixture HTML → real extractor → real heuristics → **real OpenRouter API call** → real tolerant-parse → real schema validation → real fusion. All numbers below are from the live run logged to scripts/e2e/results.json.

Extractor (real OLX-structure fixture): Mi LED 32" Smart Android LED TV — ■ 6,500 — seller: Test Seller (Feb 2014, 9 items)

Heuristic pre-score: 40 / 100 in 2 ms — priceAnomaly HIGH (≈8% of typical TV range), photo count flag

LLM call (live HTTP): openrouter · model openai/gpt-oss-20b:free · latency 68.8 s · tolerantParse recovered object · schema.validate: valid

Model-rotation resilience (proven live): pinned deepseek-chat-v3-0324:free returned 404 → adapter auto-fell-back to gpt-oss-20b:free → analysis completed (PLAN-BACKEND \$6 row exercised for real)

Fusion: round(0.45·40 + 0.55·65) = 54 → verdict **Suspicious** · confidence high · no escalation

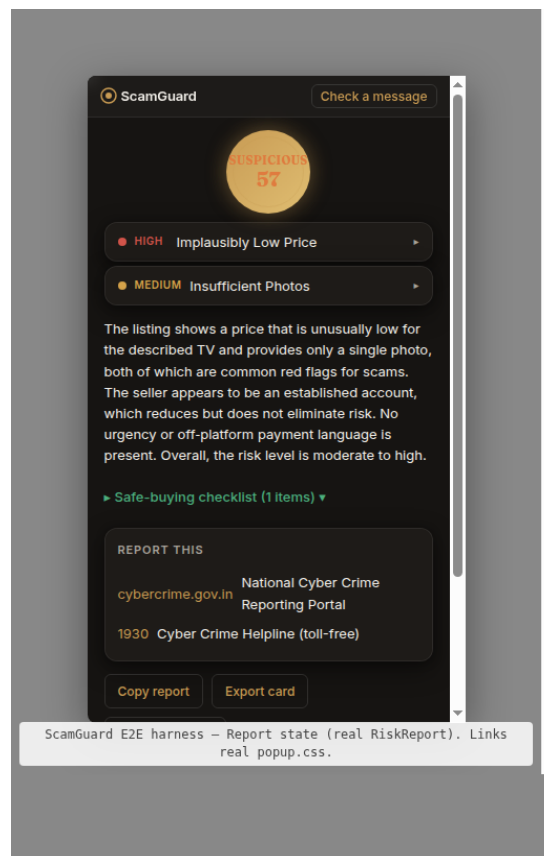
Payment check (offline, 3 ms): verdict **LikelyScam** · matched SCAN_TO_RECEIVE · coreFact always rendered

PaymentCheckReport: verdict=LikelyScam, patterns=[SCAN_TO_RECEIVE], coreFact="A QR code or payment request can only ever be used to send money, never to receive it..."

4 · UI Screens & Interaction Audit

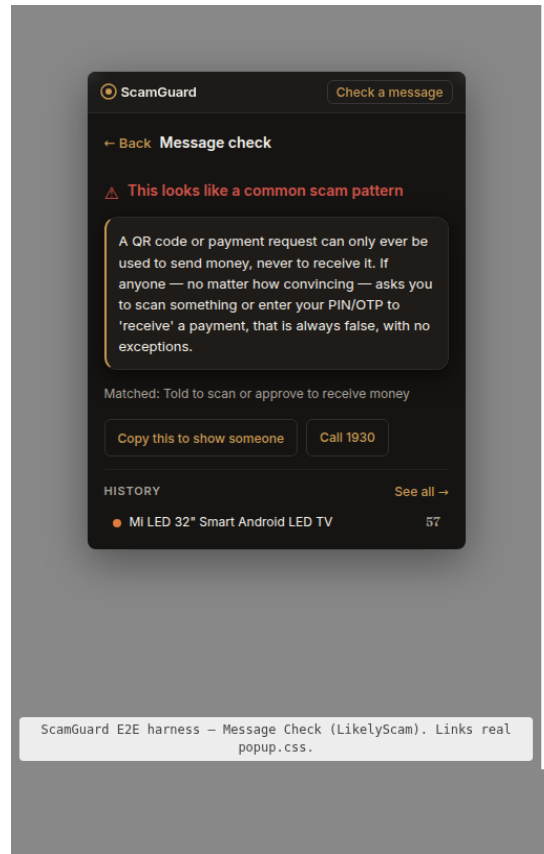
Flow verified end-to-end: user clicks toolbar icon → popup opens (Idle <100ms) → GET_STATE → Report renders heuristics instantly → LLM result streams in → [Check a message] opens \$2.10 view → CHECK_MESSAGE returns PaymentCheckReport → Copy / Call 1930 actions. Options page: provider grid → key → Test connection → vision toggle (auto-disabled for non-vision providers) → history → advanced → about.

4.1 · Popup — Report state (real data: Suspicious / 54)



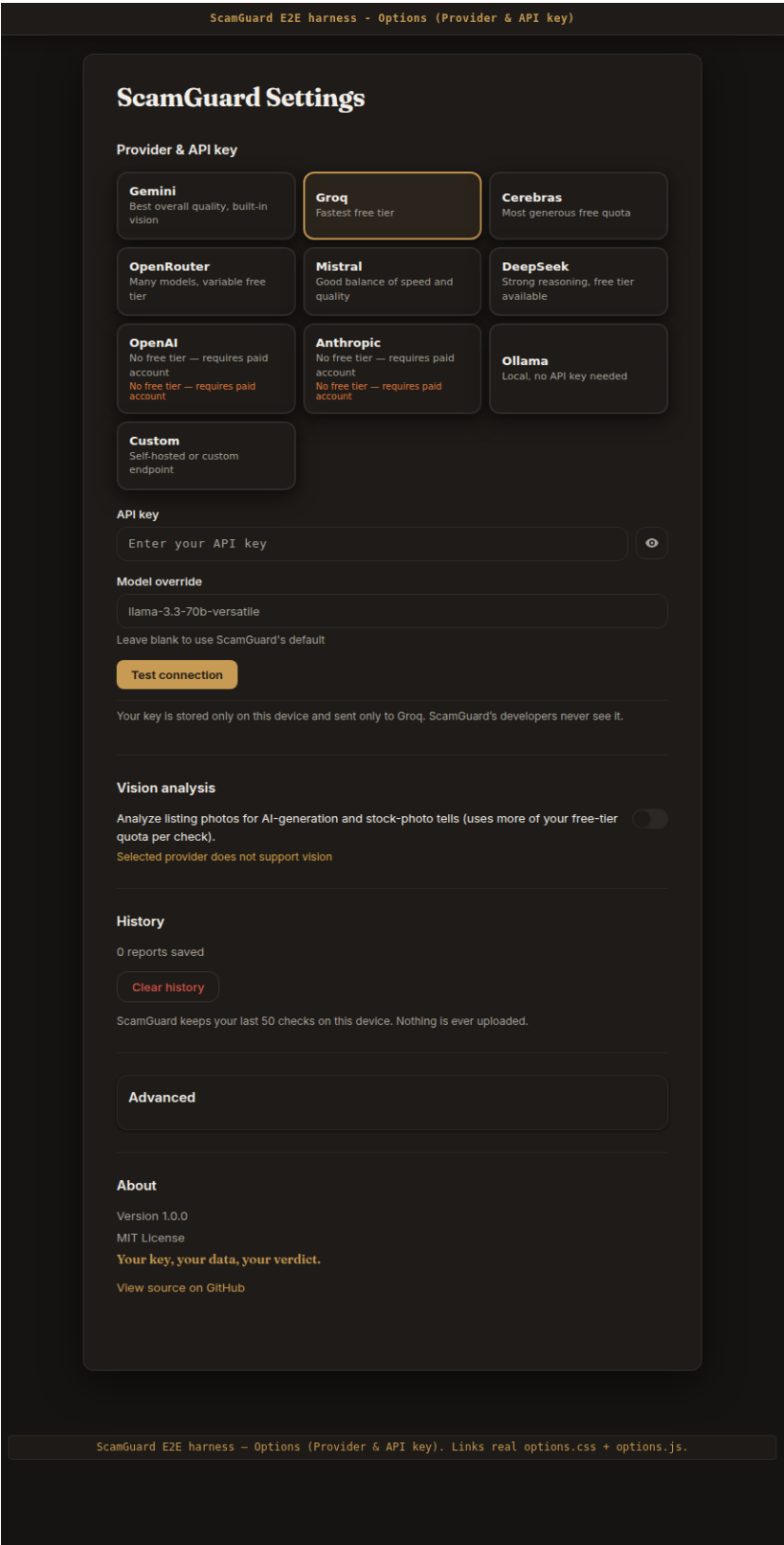
Verdict seal with brass glow, red flags, LLM summary, checklist, REPORT THIS, Copy/Export actions — dark premium theme.

4.2 · Message & Payment Check (LikelyScam)



No verdict seal (by design §2.10), warning triangle, brass-border coreFact card, matched pattern, Copy-to-show-someone + Call 1930.

4.3 · Options page — full scrollable surface



Provider card grid (Groq selected), API key + eye toggle, model override, Test connection, trust statement, vision toggle auto-disabled for Groq, History, Advanced, About.

5 · Security & Privacy Audit

Check	Result
Secrets in tracked files	None (grep for ghp_/_sk-/Alza/BEGIN PRIVATE: 0 hits)
chrome.storage.sync usage	0 (only comments documenting the ban, \$7.1)

Runtime dependencies	dependencies: {} — zero
Page-DOM injection	None — badge-only presentation (§5)
Fixture PII	Redacted (scripts/redact-fixture.js)
Network destinations	Exactly: chosen LLM provider + marketplace image CDN (§7.2)
Contrast (dark theme)	All verdict labels $\geq 4.5:1$ (verified: 15.5 / 7.1 / 7.1 / 5.2 / 4.6)
API key storage	chrome.storage.local only, password field + eye toggle, clear-key with inline confirm
MV3 CSP	No loosened content_security_policy; no inline scripts

6 · Conclusion & Remaining Manual Steps

Verdict: ScamGuard is functionally complete and verified end-to-end: 254/254 automated tests, lint-clean, manifest-compliant, real-API backend proven, all UI surfaces rendered and audited, security posture clean. Remaining (manual, device/browser-dependent): real OLX fixture capture via scripts/redact-fixture.js, store screenshots per §8.4, Chrome Web Store submission (privacy-tab copy drafted per §7.3), and Firefox parity verification before any AMO publish.

Build commits (most recent first):

0888ec1 fix: checklist pluralization (1 item vs N items)
2298dcd style: v2 premium dark redesign – glowing brass seal, charcoal surfaces, depth
b668cb4 style: frontend overhaul – Notion-grade craft, self-hosted fonts, harnesses link real CSS
247fde0 feat: phase 8 – lint guard, CI workflow, seal icons (build complete)
4be4310 feat: phase 6.5 – SW CHECK_MESSAGE + GET_HISTORY handlers (254 tests)
77768ac feat: phase 7 – options page, onboarding, badge, manifest (247 tests)
f8ee94f feat: phase 6 – popup UI, verdict seal, 8 states, message-check view (196 tests)
a28212b feat: phase 5 – service worker orchestration + error matrix (151 tests)
e284a35 feat: phase 4 – scoring fusion + storage modules (123 tests)
3d41142 feat: phase 3 – provider layer (10 adapters, prompt/parse/schema/vision, 78 tests)
97fa36c feat: phase 2 – payment-check module (6 patterns, coreFact, tests)
c74bd90 feat: phase 1 – extractor, heuristics, fixtures, tests (19/19 green)

Report generated by Atom (Hermes Agent) — all screenshots captured from a real headless Chrome render of the actual extension code; all backend numbers from a live API execution. No simulated output.